

HTB CPTS

Certified Penetration Testing Specialist

Présentation : certification, path, prix, exam, préparation, cheatsheets, labs utiles, comparaison PNPT & CWES, avis personnel.

By @Top0n3

Objectif de la présentation

01 Comprendre la CPTS

Positionnement, public cible, valeur réelle

02 Décortiquer le path

Modules, compétences, charge de travail

03 Comprendre l'examen

Format, rapport, stratégie et pièges

04 Préparer intelligemment

Cheatsheets, labs, planning, méthode

05 Comparer

CPTS vs PNPT, CPTS vs CWES, ordre conseillé

06 Avis personnel

Niveau, ROI, recommandations

1. CPTS en 60 secondes

Résumé exécutif

10 jours

Accès exam + soumission rapport

28 modules

Penetration Tester Job Role Path

342h

Estimation HTB du path

\$210

Voucher hors TVA

2 essais

Tentative + retake inclus

Idée centrale

CPTS évalue ta capacité à conduire un pentest réaliste : énumération, exploitation web/interne, privilège, Active Directory, pivoting, chaînage de vulnérabilités et rapport commercial exploitable.

Ce n'est pas seulement "pwn des boxes". C'est une certification de méthodologie, persévérance, documentation et d'exploitation contrôlée dans un environnement d'entreprise très réaliste.

Pourquoi CPTS est différente

Une certification "job-role", pas un simple quiz

Approche terrain

Pas de QCM
Scénario de réseau d'entreprise
Chaînage de vulnérabilités
Exploitation + preuve + impact

Méthodologie

Reconnaissance structurée
Énumération itérative
Hypothèses et validation
Gestion du scope

Reporting

Notes exploitables
Screenshots propres
Rapport commercial
Remédiations actionnables

CPTS récompense la capacité à aller au bout d'une chaîne d'attaque, puis à l'expliquer comme dans une mission client.

Pour qui ? Avec quels prérequis ?

Positionnement réaliste

Public cible

- Junior/intermediate pentester qui veut structurer sa méthodologie.
- Bug bounty hunter voulant sortir du web pur et entrer dans l'infrastructure/AD.
- Étudiant cyber voulant une certification pratique et profonde.
- Blue teamer voulant comprendre les chemins d'attaque réalistes.

Prérequis conseillés

- Réseau : TCP/IP, ports, services, DNS, HTTP/HTTPS, SMB, Kerberos.
- Linux/Windows : ligne de commande, permissions, processus, fichiers.
- Web : Burp, fuzzing, auth, SQLi, XSS, upload, LFI/RFI, API basics.
- AD : énumération, Kerberoasting, mouvements latéraux, privesc.
- Mental : notes propres, patience, troubleshooting, reporting.

2. Le path officiel : Penetration Tester

Le cœur de la certification

495

sections

28

modules

1970

cubes requis

450

cubes reward

342h

estimation HTB

23

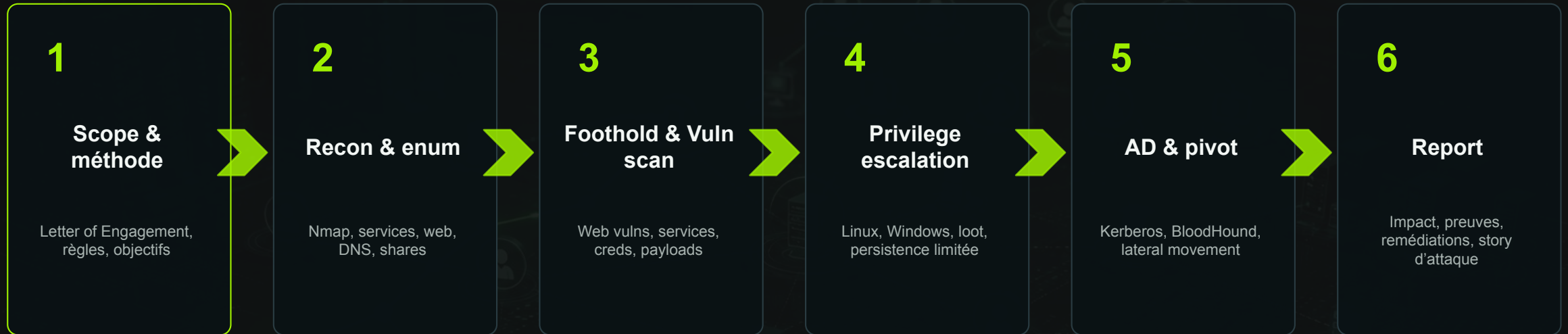
skills assessments

Logique du path

HTB Academy impose la complétion à 100% du Job Role Path avant de lancer l'examen. Ce modèle évite l'approche "je grind des boxes au hasard" : tu passes par les bases, l'énumération, le web, l'exploitation, l'AD, le pivoting, puis le reporting/capstone.

Carte des compétences couvertes

Du premier scan au rapport final



La compétence clé est l'énumération itérative : chaque nouvel accès doit relancer la découverte.

Modules du path : vue groupée

Introduction

- Penetration Testing Process
- Getting Started

Recon & Enum & Attack planning

- Network Enumeration with Nmap
- Footprinting
- Information Gathering - Web
- Vulnerability assessment
- Shell & Payload
- File Transfers
- Using MSF

Exploitation & Lateral Movement

- Password Attacks
- Attacking common services
- Pivoting & Tunneling & port forwarding
- AD enumeration & Attacks

Web-exploitation

- Attacking Web with FFUF
- Using web proxy
- Login brute forcing
- SQLI fundamental
- SQLMap Essential
- XSS
- File upload attacks
- File Inclusion
- Command Injection
- Web Attacks
- Attacking Common Applications

Modules du path : vue groupée

Post Exploitation

- Linux PrivEsc
- Windows PrivEsc

Reporting & Caption

- Documentation & Reporting
- Attacking Enterprise Network

Ce que tu apprends vraiment

Au-delà des commandes

Énumération professionnelle

Construire une hypothèse, identifier les services, mapper les relations, ne pas sauter trop vite sur l'exploitation.

Exploitation raisonnée

Adapter un exploit, chaîner web + creds + service interne, comprendre l'impact au lieu de juste prendre un flag.

AD en contexte

Trouver des chemins d'attaque dans des erreurs de config réalistes : ACL, Kerberos, shares, credentials, sessions.

Pivoting & réseau

Utiliser tunnels, port forwarding et proxychains pour atteindre des sous-réseaux non exposés.

Reporting

Transformer une attaque en rapport lisible : executive summary, preuves, risques, recommandations.

Discipline mentale

Garder un journal d'actions, versionner tes notes, éviter les rabbit holes et reprendre proprement.

L'estimation du temps pour finir le path est dépendante de la vitesse d'apprentissage et du temps consacré

Budget & options d'accès

Voucher CPTS

\$210

≈ \$249.90 avec TVA selon pays

Voucher valable 1 an
Deux tentatives incluses
Path requis avant démarrage
Pas de QCM : lab + rapport

Academy PATH

Cubes / abo

Le path CPTS peut être débloquenté via cubes ou via abonnements Academy selon ton profil.

- Silver/Gold annuels donnent des vouchers selon offre
- Gold donne accès à plus de paths avancés
- HTB Student subscription 8\$/month

Labs complémentaires

VIP+ / Pro Labs

VIP+ pour retired machines ; Pro Labs pour réseaux corporate, pivoting et AD.

VIP+ : \$25/mois ou \$223/an
Pro Labs : \$49/mois ou \$490/an
Non obligatoires mais utiles si tu veux sur-préparer

Toolbox typique pour CPTS

Exemples à organiser dans tes notes

Recon / enum	nmap, rustscan, masscan, whatweb, dnsrecon, gobuster/ffuf
Services	smbclient, enum4linux-ng, netexec, rpcclient, ldapsearch, snmpwalk
Web	Burp Suite, ffuf, sqlmap, curl, , XSSStrike, wappalyzer.
Exploitation	Metasploit, searchsploit, custom Python/Bash, payloads, reverse shells
Post-exploitation	linpeas/winpeas, pspy, Seatbelt, PowerView, LaZagne, mimikatz*
AD / pivot	BloodHound, impacket, Responder, chisel, ligolo-ng, proxychains, sshuttle
Reporting	CherryTree/Obsidian, Markdown, screenshots, CVSS, report template

**Toujours rester dans le scope autorisé et documenter les actions significatives.*

3. Format de l'examen CPTS

Ce qui est évalué

Durée

10 jours pour tester le lab et soumettre le rapport.

Objectifs

Flags + compromission progressive + rapport professionnel.

Retake

Voucher avec deux tentatives ; feedback après un échec.

Environnement

Instance dédiée de lab, possibilité de reset, accès via Pwnbox ou ton setup.

Rapport

Soumission via dashboard officiel, en anglais, sur base du template HTB.

Résultat

Évaluation technique + qualité du rapport, résultat annoncé après revue.

Stratégie pendant les 10 jours

Plan de bataille pratique



Règle d'or : commencer le rapport dès le premier jour. Une vulnérabilité non documentée proprement peut devenir une vulnérabilité "perdue".

4.Préparation intelligente : les 8 piliers

Objectif : arriver à l'examen avec une méthode reproductible, pas juste beaucoup de théorie.

01 Path à 100%

Comprendre chaque module, pas seulement valider.

02 Assessments

Les refaire sans blocage ni dépendance aux notes.

03 CPTS Track

Complément très important : techniques parfois absentes du path.

04 Discord HTB

Lire les retours, poser les bonnes questions, éviter les erreurs.

05 Notes propres

Procédures par service, scénario et décision.

06 Cheatsheets

Commandes complètes, variables, explication et sortie attendue.

07 Labs ciblés

Pro Labs optionnels ; pratiquer sans se perdre dans le "surlearning".

08 Module AEN

Accomplir l'AEN sans le write up

Étape 1: Path CPTS à 100 % (Sans AEN)

Le path officiel reste la base absolue : il faut le maîtriser avant d'empiler d'autres ressources.

Priorité absolue

- Ne pas courir vers les Pro Labs avant d'avoir fini le path.
- Revoir les modules faibles : énumération, privesc Windows/Linux, AD, pivoting, reporting.
- Reproduire les commandes manuellement pour comprendre les options.
- Transformer chaque module en procédure exploitable pendant l'exam.

MINDSET : comprendre > mémoriser > copier

Skills assessments : le vrai test

- Refaire les assessments sans regarder la solution.
- Être capable d'expliquer pourquoi chaque étape marche.
- Noter les blocages : service oublié, mauvaise wordlist, privesc ratée, pivot mal compris.
- Refaire jusqu'à ne plus avoir de difficulté majeure.

Critère de readiness

Tu sais refaire un assessment similaire avec tes propres notes et sans "panic search".

Étape 2 : Faire la CPTS Track HTB

Très important : certaines techniques utiles au succès de l'examen ne sont pas forcément détaillées dans le path.

Pourquoi ?

- Complète les angles morts du path.
- Expose des techniques et scénarios plus proches du terrain HTB.
- Force à chaîner plusieurs modules au lieu de les pratiquer isolément.

Comment ?

- La faire après le path principal.
- Documenter les techniques nouvelles dans tes playbooks.
- Ne pas juste “résoudre” : refaire les étapes à froid.

Livrable

- Une liste “techniques CPTS Track” séparée.
- Des commandes template avec variables.
- Des scénarios : quand tester quoi, avec quels indices.

Important : ce n'est pas optionnel si tu veux maximiser tes chances.

Étape 3 : Faire l'AEN en aveugle avant l'examen

AEN est le module final qui simule à 70% l'examen réel de la CPTS

Pourquoi ?

- Pour tester ta méthodologie
- Identifier les points faibles

Comment ?

- Lance le module et commence le pentest
- Compromet tout les app web
- Fait du pentest interne jusqu'à la compromission du DC

Livrable

- Un rapport de pentest complet bien documenté selon les notions enseignées dans le module Reporting

Important : C'est le dernier point décisive avant l'examen

Communauté : Discord HTB CPTS

Le salon dédié CPTS est une source de retours d'expérience, d'indices de préparation et de clarification.

Ce que tu dois y faire

- Lire les messages épinglés / FAQ du salon CPTS.
- Rechercher les discussions avant de poser une question.
- Repérer les conseils récurrents : report, notes, pivoting, time management.
- Demander de l'aide sur la méthode sans demander de spoilers.

Règle : pas de spoilers, pas de flags, pas de détails d'examen

Questions intelligentes à poser

- “Comment structurer mes notes pour les services internes ?”
- “Quels types de labs sont utiles après le path, sans spoiler ?”
- “Comment gérer la fatigue sur 10 jours ?”
- “Comment améliorer la qualité du rapport ?”
- “Quelles erreurs fréquentes à éviter pendant la préparation ?”

Notes & procédures : ton vrai avantage

Pendant CPTS, les notes doivent être actionnables : scénarios, décisions, commandes et preuves.

1. Scénarios

- Si SMB ouvert : enum shares, users, null session, creds reuse.
- Si HTTP interne : vhosts, fuzzing, auth bypass, upload, LFI, SSRF.
- Si domaine AD : users, SPN, AS-REP, LDAP, BloodHound, ACL.
- Si nouvelle machine : re-scan local + services internes + routes.

2. Procédures

- Objectif
- Préconditions
- Commandes
- Interprétation
- Prochaine action

3. Preuves

- IP, hostname, user, date.
- Commande + sortie importante.
- Screenshot lisible.
- Impact métier/risk.
- Chemin d'exploitation complet.

Principe : tes notes doivent te dire quoi tester ensuite, pas seulement ce que tu as déjà fait.

Cheat Sheets opérationnelles : exemple Kerberoasting

Une bonne cheat sheet contient la commande complète, les variables, l'objectif et la sortie attendue.

Template recommandé

- Contexte : domaine AD accessible + identifiants valides.
- But : extraire les tickets TGS des comptes avec SPN.
- À vérifier : heure du système, DNS, accès DC, format domaine.
- Sortie attendue : hash \$krb5tgs\$ crackable offline.
- Prochaine action : crack → password reuse → accès service.

Variables DOMAIN.local | USER | PASS | DC_IP | rockyou.txt

```
# Option 1 - Impacket
GetUserSPNs.py DOMAIN.local/USER:'PASS' -dc-ip DC_IP -request
-outputfile kerberoast.hashes

# Option 2 - NetExec
netexec ldap DC_IP -u USER -p 'PASS' --kerberoasting kerberoast.hashes

# Crack
hashcat -m 13100 kerberoast.hashes /usr/share/wordlists/rockyou.txt

# Après crack
netexec smb <target_range> -u <user> -p <cracked_password> --shares
```

À faire pour SMB, LDAP, MSSQL, WinRM, FTP, SNMP, Web, Pivoting, Privesc Linux/Windows

Labs utiles, mais sans se perdre

Les Pro Labs peuvent aider, mais ils ne doivent pas remplacer le path, la CPTS Track et les assessments.

Pro Labs / machines : optionnels mais utiles

- Choisir des labs qui renforcent tes faiblesses : AD, pivoting, Windows/Linux privesc, web interne.
- Documenter chaque lab comme un mini-rapport CPTS.
- Après chaque lab : extraire 3 procédures réutilisables.
- Exemples à considérer : Dante / Zephyr / Offshore selon ton niveau .

Rôle des labs : pratiquer la méthode, pas collectionner des flags.

Éviter le surapprentissage

- Ne pas ouvrir 200 ressources en parallèle.
- Ne pas apprendre des techniques ultra rares avant de maîtriser les bases.
- Ne pas changer d'outil toutes les semaines.
- Ne pas confondre "je connais la commande" avec "je sais quand l'utiliser".
- Stop quand tes notes couvrent les scénarios fréquents et que les assessments passent proprement.

Liens utiles & reviews

Page modifiable : ajoute ici les ressources qui t'aident à mieux t'apprêter sans spoiler l'examen.

Catégorie	Lien / source	Pourquoi c'est utile ?
Review CPTS 1	https://www.brunorochamoura.com/posts/cpts-experience/	Bien détaillé
Review CPTS 2	[https://blog.gzzcoo.com/posts/Certified-Penetration-Testings-Specialist-(CPTS)-2026-Review/	Piste sur l'examen
HTB Discord / CPTS	https://discord.gg/hackthebox	Discussion / Question
HTB reddit	https://www.reddit.com/r/hackthebox/	Retour d'expériences
sysreptor HTB	https://htb.sysreptor.com/htb/signup/	Pratique pour l'écriture de rapport de pentest
Note taking	https://obsidian.md/	utile pour la prise de notes

privilégier les reviews qui parlent de préparation et stratégie, pas celles qui cherchent à spoiler.

Niveau de difficulté

Évaluation honnête

Débutant pur

Junior pentester

Intermédiaire

Senior

CPTS

Pourquoi c'est dur

Volume du path, densité technique, énumération longue, fatigue sur 10 jours, rapport obligatoire.

Ce qui aide

Avoir PNPT, une vraie méthode de notes, de bonnes bases web, privesc et AD.

Ce qui fait échouer

Rabbit holes, copier-coller sans comprendre, rapport commencé trop tard, mauvaise gestion du scope.

4. CPTS vs PNPT

Comparaison utile si tu as déjà PNPT

Critère	CPTS	PNPT
Éditeur	Hack The Box Academy	TCM Security
Format	Lab 10 jours + rapport + flags	5 jours pentest + 2 jours report + debrief live
Focus	Méthodologie très large : web, interne, AD, pivot, report	Réseau/AD, OSINT, compromission DC, communication client
Préparation	Path Academy obligatoire à 100%	Training inclus, pas même logique de path obligatoire
Style	Plus "technique dense / HTB-like"	Plus "mission pentest réaliste / client-like"
Prix exam	≈ \$210 hors TVA	≈ \$499 voucher+training de base
Avantage	Profondeur technique et volume énorme	Très réaliste côté déroulé + debrief oral
Limite	Moins reconnu RH que OSCP dans certains marchés	Moins profond web/HTB Academy que CPTS

CPTS vs CWES : lequel passer en premier ?

Passer CPTS d'abord si...

- Tu veux une base pentest complète, pas seulement web.
- Tu veux progresser en réseau, privesc, AD, pivoting et reporting.
- Tu as déjà PNPT et tu veux renforcer la profondeur technique HTB.
- Tu vises ensuite CAPE, CRTO/OSEP, ou une trajectoire red team.

Passer CWES d'abord si...

- Ton objectif principal est web pentest / bug bounty.
- Tu veux renforcer les vulnérabilités web modernes et le mindset applicatif.
- Tu as déjà une base infra/AD suffisante et tu veux spécialiser ton profil.
- Tu veux capitaliser vite sur ton expérience web ou CWES/CBBH-like.

Mon conseil : CWES est très cohérent avant CPTS. (FINIR le Web, comprendre HTB examen Mindset

Erreurs fréquentes à éviter

Leçon de préparation

✗ Passer trop vite les bases

Les failles viennent souvent de détails d'énumération.

✗ Se reposer uniquement sur LinPEAS/winPEAS

Automatiser oui, mais vérifier manuellement.

✗ Ne pas mapper le réseau

Sans schéma, le pivoting devient chaotique.

✗ Mauvaises captures

Capture illisible = preuve faible dans le rapport.

✗ Trop de rabbit holes

Fixer des timeboxes et revenir aux hypothèses.

✗ Rapport à la fin

Tu risques d'oublier des preuves critiques.

6. Avis personnel

Verdict

CPTS est probablement l'une des meilleures certifications pratiques pour construire une vraie méthodologie de pentest intermédiaire. Elle est exigeante, longue, frustrante, mais très formatrice.

À faire

Compléter le path sérieusement, refaire les assessments faibles, écrire le rapport dès le début.

À éviter

Consommer trop de writeups, commencer Pro Labs avant d'avoir corrigé ses bases, négliger le web.

ROI

Excellent pour compétence technique ; reconnaissance marché variable selon pays/entreprises.

Questions ?

Discussion : stratégie de préparation, ordre PNPT/CPTS/CWES, labs utiles, gestion de l'examen et reporting.

Contact: [Linkedin](#) [Blog](#)